



UniKL
UNIVERSITI
KUALA LUMPUR

IKB42603 • Cloud Security

WEEK 2 • LESSON 2

Security Design & Architecture for Cloud Computing

Design principles • Four pillars • CSA • NIST • ENISA • Threats



What you will be able to do



1. Explain cloud security design principles

Defense in depth, least privilege, zero trust, security by design.

2. Understand the CIA triad

Confidentiality, integrity and availability as the goal.

3. Describe the four security pillars

Isolation, data protection, access control, monitoring.

4. Apply access-control concepts

IAM, authentication and authorization (RBAC/ABAC).

5. Recognise cloud security standards

CSA, NIST and ENISA guidance.

6. Identify common cloud threats

Attack vectors and the role of misconfiguration.

Curriculum alignment — CLO · PLO · MQF · clusters

CLO 1

Examine how cloud computing security concepts are applied to solve real-world technical problems.



Programme outcome

PLO1 · Knowledge
MQF Level i
Bloom C3 (Apply)



Values & skills

SC1 · System Thinking



Sustainability (SDG)

SDG 9.1
Resilient, inclusive infrastructure



Assessment

Test
Final Test

Constructive alignment: CLO → PLO → MQF, with VBE (values), SC (skills) and SDG clusters, assessed as shown.

01

PART 1

Foundations of Cloud Security Architecture



UniKL
UNIVERSITI
KUALA LUMPUR

DEFINITION

What is cloud security architecture?

A deliberate framework that protects cloud systems by combining policies, technologies and controls into one coherent design.



Policies — Rules & governance



Technologies — Encryption, IAM, firewalls



Controls — Preventive & detective



Security must be built IN, not bolted ON.

Bolted-on security is costly, incomplete and brittle — the root of most cloud breaches.

Every control serves one goal: *the CIA triad — confidentiality, integrity, availability.*

The CIA triad — what security protects



Confidentiality

Only authorised parties can read the data.

Encryption · access control



Integrity

Data is accurate, unaltered — and provably so.

Hashing · signatures · tamper-proof logs



Availability

The service is there when users need it.

Redundancy · backups · DDoS protection

The three are in tension — good architecture balances them to the data's sensitivity.

02

PART 2

Guiding Security Design Principles



UniKL
UNIVERSITI
KUALA LUMPUR

Four principles that guide every design



Defense in depth

Layer independent controls — no single point of failure.



Least privilege

Grant only the access truly needed.



Zero trust

Never trust, always verify — every time.

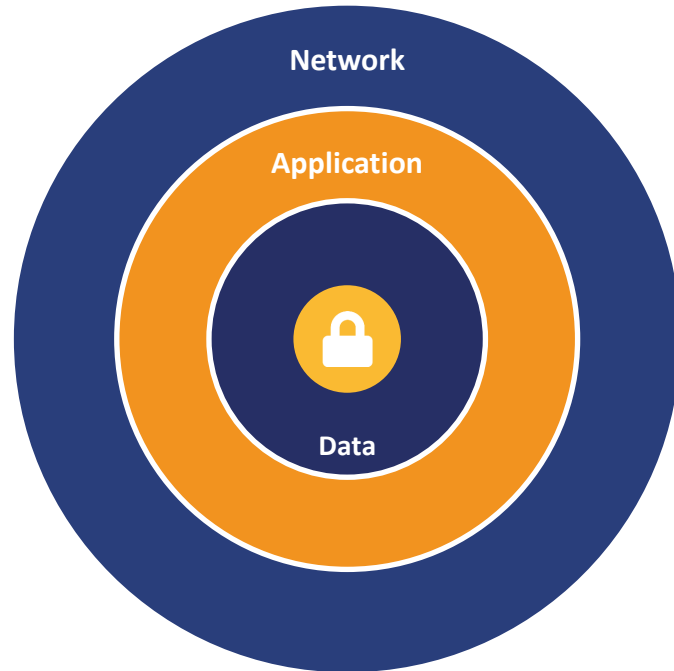


Security by design

Build security in from the first decision.

PRINCIPLE 1

Defense in depth — layered security



Multiple independent layers

- If one layer fails, others still hold
- Covers network, application and data
- Add identity as a layer in the cloud
- No single failure is catastrophic

Think of a castle: *moat, walls, guards, locked keep — the attacker must defeat every layer.*

Least privilege — only what is needed



Grant the minimum access required — and nothing more.

Blast-radius reduction: *a compromised account inherits only its own limited permissions.*



Right-size every role

People and machine identities alike.



Avoid over-provisioning

'To save time' is how breaches spread.



Fight permission creep

Review and revoke access regularly.

PRINCIPLE 3

Zero trust — never trust, always verify

There is no trusted 'inside' any more — verify every request, every time, wherever it comes from.



Verify explicitly

Authenticate & authorise using every signal — identity, device, location, behaviour.



Assume breach

Design as if the attacker is already inside; segment and monitor.



Least-privilege access

Just-in-time, just-enough, tightly scoped access.

Applies to users, devices AND systems — trust is earned per request, never granted by location.

PRINCIPLE 4

Security by design — build it in early



Security is integrated from the first architecture decision — never added as an afterthought.



Secure coding

Input validation, safe defaults, no hard-coded secrets.



Risk assessment

Identify & rate threats before building.



Architecture planning

Encryption, IAM, segmentation, logging in the blueprint.

Shift left: *fixing a flaw at design time is far cheaper than after a breach.*

03

PART 3

The Four Pillars of Cloud Security



Four pillars — and where the course goes next

Lesson 3



Secure isolation

Keep tenants separated on shared infrastructure.

Lesson 4



Data protection

Protect data at rest, in transit and in use.

Lesson 5



Access control

Only authorised identities reach resources.

Lesson 6



Monitoring & auditing

See what happens — and prove it.

Data protection across the lifecycle



At rest

Stored on disk / in buckets

Encryption · secure storage · access policies



In transit

Moving across networks

TLS / HTTPS to prevent interception



In use

Being processed in memory

Memory protection · confidential computing

Protection must be continuous — a gap in any one state is a gap overall.

End-to-end access control (IAM)



IAM ensures only authorised identities reach resources — identity is the new perimeter.



Authentication

“Who are you?”

Prove identity — passwords, MFA, biometrics.



Authorization

“What can you do?”

Decide permissions — RBAC, ABAC.

Authentication methods & authorization models



Authentication — proving identity

- **Password-based** — Weakest alone; phishable
- **Multi-factor (MFA)** — Adds have/are — defeats most attacks
- **Biometrics** — Strong 'something you are'



Authorization — granting permission

- **RBAC** — By role — simple, scalable workhorse
- **ABAC** — By attributes — fine-grained, context-aware
- **Least privilege** — Both enforce minimum access

Monitoring & auditing



Prevention eventually fails — monitoring and auditing are how you detect and prove what happened.



Monitoring

Continuous logging & threat detection.



Auditing

Periodic review for compliance & investigations.



Benefits

Early detection · faster response · compliance.

04

PART 4

Standards & Frameworks



Three frameworks that shape cloud security



CSA

Cloud Security Alliance

Industry best practice · Cloud Controls Matrix (CCM). Source of CCSK.



NIST

US Nat. Institute of Standards

SP 800-53 · Risk Management Framework.
Widely adopted worldwide.



ENISA

EU Agency for Cybersecurity

Risk assessment · secure cloud-adoption
guidance (EU).

Frameworks give you a shared vocabulary, a control checklist, and evidence for auditors.

05

PART 5

Threats, Case Study & Practice



UniKL
UNIVERSITI
KUALA LUMPUR

Attack vectors & cloud-specific threats

Common attack vectors



Phishing



Malware injection



API attacks



DoS / DDoS

Cloud-specific threats



Data breaches



Misconfiguration



Insider threats



Account hijacking

Misconfiguration — most breaches are human error



Most cloud breaches are not exotic hacks — they are simple configuration mistakes.

Why? *resources created in seconds, powerful defaults, no gatekeeper.*



Open storage buckets

Public to the whole internet.



Weak permissions

Overly broad, rarely reviewed.



Incorrect settings

Insecure defaults shipped to prod.

Case study — the exposed storage bucket



A company exposes sensitive customer data: a storage bucket was left publicly readable, permissions were overly broad, and nothing was monitoring it.

What went wrong?

Misconfiguration · broken least privilege · no security-by-design · no monitoring

How to prevent it?

Private defaults · least privilege · encryption · CSPM monitoring · follow a standard

Best practices — designing securely



Apply least privilege

People and machine identities alike.



Encrypt data in every state

At rest, in transit and in use.



Enable monitoring & auditing

From day one, not after an incident.



Follow a standard

CSA, NIST or ENISA — don't improvise.



Run regular audits

Catch drift before attackers do.



Design security in early

Build it in, don't bolt it on.

Key takeaways



1 Security must be designed in early — aiming at the CIA triad: confidentiality, integrity, availability.



2 Four principles guide design: defense in depth, least privilege, zero trust, security by design.



3 Four pillars structure the work: isolation, data protection, access control, monitoring.



4 Build on standards (CSA/NIST/ENISA) — and remember misconfiguration causes most breaches.



Discussion & Q&A

- Which design principle do you think is most important — and why?

If most breaches are misconfiguration, where should an organisation invest first to reduce cloud risk?

Next week — Lesson 3: Secure Isolation of Physical & Logical Infrastructure